INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Governance, Compliance, and Risk (GCR)
Phase 2, Course 5: GRC205 - Incident Management and Business Continuity

Theory-Based Assignment:

The "Northbridge Skills Institute"Incident

Student Name: Chioma Chinonyelum Onyekelu

Student ID: 2025/GCR/12696

Official Email: gcr2512696@students.icdfa.edu.ng

Instructor Name: Mr. Aminu Idris, AMCPN

Date: 17/10/2026

Learning Outcomes:

Through the analysis and resolution of the Northbridge Skills Institute incident scenario, the following core capabilities were demonstrated and applied in this report:

1. **Incident Classification & Prioritisation:** Analyzed multi-source evidence (E01–E08) alongside business constraints (11:00 WAT exam) to classify incident severity and establish threat containment priorities.
2. **Incident Response Plan Development:** Developed an operational policy and plan establishing emergency isolation authorities, out-of-band documentation standards, and a single-accountability RACI matrix across CSIRT roles.
3. **Lifecycle Execution:** Sequenced technical response procedures from immediate containment and chain-of-custody evidence preservation to validated clean-room restoration.
4. **Evaluation & Improvement:** Aligned technical incident containment with business continuity execution and established post-incident review mechanisms to remediate institutional vulnerabilities.

ABSTRACT

In this assignment exercise, I explored the incident management, incident classification, business continuity, and digital forensic response capabilities of Northbridge Skills Institute, aligned with the objectives of the **ICDFA GRC205 Incident Management and Business Continuity curriculum**. I began by establishing **foundational incident telemetry through an evidence-linked timeline (E01–E08**) to support technical triage, hypothesis testing, and severity assessment following a suspected multi-system ransomware attack. I then **examined severity classification frameworks,** classifying the event as a Critical incident due to operational impacts on scheduled examinations, potential data exfiltration, and compromised backup accounts.

Next, I developed **an operational Incident Response Policy and Plan (IAP)** covering mission, objectives, scope, emergency system isolation authorities, out-of-band documentation standards, and integration with business continuity frameworks. I also configured a **multi-disciplinary Computer Security Incident Response Team (CSIRT) structure**, established a **single-accountability RACI matrix** across key response activities, and detailed readiness preparation improvements covering immutable backups, contact lists, and server EDR deployment. Furthermore, I **designed a 24-hour response playbook**, created a **chain-of-custody evidence register**, established **clean-room recovery acceptance criteria**, and drafted **multi-stakeholder communication matrices, executive briefings**, and **regulatory notification workflow**s under the **Nigeria Data Protection Act 2023**. Finally, I conducted **a simulated 60-minute tabletop exercise with injects**, evaluated an **illustrative healthcare ransomware case study**, and formulated **actionable post-incident improvement plans**.

Overall, this assignment enhanced my practical understanding of how incident response planning, digital evidence preservation, crisis communications, and business continuity provide an integrated framework for cyber resilience and regulatory compliance. It also strengthened my ability to configure and execute structured incident response protocols within an active organizational environment.

Scenario Introduction and Evidence

Northbridge Skills Institute

Northbridge Skills Institute is a fictional education and training provider with 1,800 learners and 90 staff. It holds learner contact details, admission documents, assessment records, and finance files. An online examination for 100 learners is scheduled for 11:00 on Day 0. You take control of the incident at 08:45 on Day 0, a Monday. All times are West Africa Time (WAT).

Its systems are FIN-PC07, a finance workstation; FS01, the shared file server; LMS01, the learning portal; and BAK01, the network backup repository. Microsoft 365 provides identity and email. The portal depends on files stored on FS01. The svc_backup account has administrator access to FS01 and BAK01.

The last disconnected backup is from 17:00 on Day minus 3, the preceding Friday. Network backups are not immutable. Neither backup route has undergone a restoration test in the last 90 days. EDR covers workstations, but server coverage is incomplete. The IT team has three staff and one security analyst.

Initial evidence pack

ID	Time WAT	Source and observation
E01	Day minus 1 16:40	User report and mail record: a finance officer opened an unexpected payroll attachment on FIN-PC07. Execution of malicious code is not yet verified.
E02	Day 0 01:15	Microsoft 365 audit: the finance officer account signed in from an unfamiliar IP and new device. MFA status and the user's involvement are unknown.
E03	Day 0 01:35	Windows logs: svc_backup made remote administrator logons to FS01 and BAK01 outside its usual schedule. The reason is unknown.
E04	Day 0 01:50	Proxy record: FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage. The record does not reveal the transferred content.
E05	Day 0 02:00	Backup console: the FS01 and LMS01 job reports success. Recoverability and freedom from compromise have not been established.
E06	Day 0 08:30	EDR and helpdesk: mass file changes occur on FIN-PC07. FS01 shared folders contain .locked files and a ransom note. The malware family is unconfirmed.
E07	Day 0 08:40	Helpdesk: the portal login page loads, but learners cannot open materials or submit assessments. The scope of damage to LMS01 remains unknown.
E08	Day 0 08:45	Operations report: the incident contact list on FS01 is inaccessible. Staff phones are available. The trustworthiness of corporate email is unverified.

These observations do not establish attacker identity or prove that personal data was stolen. Cite evidence IDs in your decisions and label additional assumptions. Use fictional contact details and record proposed evidence collection as planned.

My Task:

Act as the Incident Response Lead for Northbridge Skills Institute, a fictional training provider facing a suspected ransomware incident.

Using the attached assessment brief, complete all six tasks. Analyse the supplied evidence, classify the incident, develop an incident response plan and RACI matrix, prepare a response playbook with evidence preservation arrangements, draft stakeholder communications, and conduct a documented tabletop simulation. Evaluate the healthcare case study in the teaching slides and recommend improvements.

My Response

Assumptions and framework I used

ID	Assumption (labelled as required)
A1	Northbridge operates in Nigeria.
A2	Northbridge is the data controller. Microsoft and other providers are data processors.
A3	I hold delegated authority from the Principal (Executive Sponsor) to isolate systems and activate the response team.
A4	T0 is Day 0 (Monday) 08:45 WAT, when I take control. Day 0 is the day of the examination.
A5	An external forensics and IR firm is available on a call-out basis. If not, it is the first improvement in Task 2.
A6	The Principal accepts a short delay to the examination if that is needed to protect learners and data.
A7	Mr Guy is the Academic Owner; Mr Paul is the CTO and Ms. Chioma is the Incident Response Lead

Framework. I organise the work using the four ICDFA teaching stages I learnt which are: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity (ICDFA, slides 6 to 13). I also aligned the plan with NIST SP 800-61 Revision 3, which uses the CSF 2.0 functions. Detect, Respond and Recover from incident response. Govern, Identify and Protect support preparation. Lastly, the Lessons I learned feed back into all functions (NIST, 2025).

Part 1: Incident Assessment and Governance

Task 1: Incident classification and initial assessment (15 marks)

a. Create a timeline using E01 to E08. Separate confirmed observations, working hypotheses, and unresolved questions. Explain at least two plausible alternative explanations for ambiguous events.
b. Classify the incident type and initial severity. Define the criteria for Critical, High, Medium, and Low severity, then justify the selected level using operational impact, affected data, and uncertainty.
c. Identify confirmed and potentially affected assets. Assess confidentiality, integrity, and availability separately. Set response priorities that address the examination deadline and possible backup compromise.
d. List at least three priority investigation questions. For each, identify the additional log, artifact, interview, or validation check that could resolve it. Explain what findings would change your severity or scope assessment.

Required outputs: incident timeline, severity assessment, and investigation priorities.

Task 2: Incident Response Plan and Team Responsibilities (20 marks)

a. Prepare a concise policy and plan covering mission, objectives, scope, incident declaration, activation and escalation rules, authority to isolate systems, documentation requirements, and plan review. Explain how the plan connects with business continuity.
b. Define a Computer Security Incident Response Team (CSIRT) with at least six roles. Include incident management, security analysis, forensics, IT operations or a business owner, legal or privacy advice, and communications. Explain how the small team will obtain additional support when needed.
c. Create a RACI matrix for at least eight activities: detection, analysis, containment, evidence handling, stakeholder communication, assessment of reporting obligations, restoration approval, and closure or review. Define Responsible, Accountable, Consulted, and Informed. Assign exactly one accountable role and at least one responsible role per activity. A combined A/R assignment is acceptable.
d. Recommend at least four preparation improvements. Include backup readiness and an accessible incident contact list. For each improvement, name the owner, resources needed, and how readiness will be checked. Cover tools, secure communication, and training where relevant.

Required outputs: policy and plan outline, team structure, RACI matrix, and readiness checklist.

ANSWERS

Task 1a. Evidence-linked timeline

Status key: **C** = confirmed observation (a log, record or report directly shows it); **H** = working hypothesis (an explanation I act on but have not proven); **U** = unresolved question.

Time (WAT)	ID	What the evidence shows (C)	Working hypothesis (H)	Unresolved question (U)
Day -3, Fri 17:00	Context	Last disconnected backup was taken. Network backups are not immutable and have not been restore-tested in 90 days.	This is the most trusted recovery point.	Is it complete and clean?
Day -1 16:40	E01	A finance officer opened an unexpected payroll attachment on FIN-PC07 (user report and mail record).	The attachment ran malicious code and gave initial access.	Did code actually execute?
Day 0 01:15	E02	The finance officer's Microsoft 365 account signed in from an unfamiliar IP and a new device.	An attacker used stolen credentials or a session token.	Was MFA used or bypassed? Was the user involved?
Day 0 01:35	E03	svc_backup made remote administrator logons to FS01 and BAK01 outside its usual schedule.	The attacker used svc_backup to move sideways and reach the backups.	Why did it happen? Was it an attacker or a change by IT?
Day 0 01:50	E04	FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage (proxy record).	Data was stolen before encryption (double extortion).	What was in the upload?
Day 0 02:00	E05	The backup console reports success for FS01 and LMS01 jobs.	The job ran, but the data may be tampered with or contain attacker tools.	Can it be restored? Is it free from compromise?
Day 0 08:30	E06	EDR and helpdesk report mass file changes on FIN-PC07. FS01 shares hold locked files and a ransom note.	Ransomware is encrypting files.	Which malware family? When did encryption start?
Day 0 08:40	E07	The portal login page loads, but learners cannot open materials or submit assessments.	LMS01 fails because the files it needs on FS01 are encrypted.	Is LMS01 itself damaged?

Time (WAT)	ID	What the evidence shows (C)	Working hypothesis (H)	Unresolved question (U)
Day 0 08:45	E08	The incident contact list on FS01 is inaccessible. Staff phones work.	The attacker's actions (or the encryption) removed access to the list.	Is corporate email safe to use?

Since, the evidence does not prove who the attacker is or that personal data was stolen, I treated both as unproven at this stage.

Task 1ai. Plausible alternative explanations for 5 ambiguous events

Event	**Explanation 1 (malicious)**	**Explanation 2 (benign or different)**	**How I would tell them apart**
E02 unfamiliar sign-in	Attacker with stolen password or token (for example a phishing proxy).	The officer used a new phone or laptop while travelling, or a contractor was given access.	Sign-in log: device ID, user agent, MFA result, location. Interview the officer.
E03 svc_backup logons	The attacker reused the svc_backup credential.	An IT member or vendor ran a catch-up or maintenance job outside schedule.	Source host and IP of the logons, command history, change tickets, IT staff statements.
E04 1.2 GB upload	Data theft before encryption.	A legitimate cloud sync, cloud backup or software upload.	Proxy and EDR file-access data, destination reputation, contents if recoverable.
E05 backup success	Backup is genuine and clean.	Backup holds attacker changes, or the attacker altered or deleted other restore points.	Read-only mount in a sandbox, malware scan, restore test, console audit log.
E06 mass file changes	Ransomware encryption.	A destructive wiper presented as ransomware.	Malware analysis, file entropy, ransom note identifiers.

Task 1b. Incident Type and Severity

Incident type: Suspected human-operated ransomware with probable data theft (double extortion). The likely route was phishing followed by credential compromise, then lateral movement to the file server and backup systems. The data theft part is *suspected, not confirmed*.

Severity criteria. Using our ICDFA teaching slide, I classified the Tiers into 4 levels and these followed the tiers and measurable tests as seen in the table below.

Level	Criteria	Response
Critical	Loss of a critical service with a fixed deadline, **or** probable exposure of sensitive personal data, **or** compromise of backups or identity systems, **or** spread across several systems.	Immediate full-team response. Executive notification within 15 minutes. External support activated.
High	Serious damage to one important service, or limited data exposure, with spread contained.	Rapid response within SLA. Management notified within 1 hour.
Medium	Limited disruption, a workaround exists, no sign of sensitive data exposure.	Standard workflow within one working day. Ticket tracked.
Low	Minimal or no impact (for example a blocked phishing email with no click).	Logged and monitored through the ticketing system.

My selected level for this incident is CRITICAL.

Justification:

1. **Operational impact.** FS01 is encrypted and the portal cannot serve materials or accept submissions (E06, E07). A 100-learner examination starts at 11:00, which is 2 hours 15 minutes after T0. The contact list is unavailable (E08).
2. **Affected data.** Northbridge holds learner contacts, admission documents, assessment records and finance files for 1,800 learners. A 1.2 GB transfer (E04) and an unfamiliar sign-in (E02) make exposure plausible.
3. **Uncertainty.** An administrator account touched both FS01 and BAK01 (E03). Backup success is unproven (E05). Server EDR coverage is incomplete, so spread cannot be ruled out. When uncertainty is this high, I classify at the worst reasonable level and re-grade as evidence arrives.

Task 1c. Affected Assets and the CIA Assessment

Asset	Status	Evidence
FIN-PC07	**Confirmed affected**	E01, E04, E06
FS01 shared file server	**Confirmed affected** (encrypted)	E06, E08
LMS01 learning portal	**Confirmed degraded**; integrity unknown	E07
BAK01 backup repository	Potentially affected (highest concern)	E03, E05
svc_backup account	Potentially compromised	E03
Finance officer's Microsoft 365 account and mailbox	Potentially compromised	E02, E08

Asset	Status	Evidence
Learner, admission, assessment and finance data	Potentially exposed	E04
Friday disconnected backup	Not known to be affected; must be protected	Context

CIA Assessment

CIA property	Assessment	Rating
Confidentiality	Theft is suspected (E02, E04) but not proven. The ransom note may threaten publication.	High (suspected)
Integrity	Files on FIN-PC07 and FS01 are altered by encryption (E06). The state of LMS01 and the backups is unknown, so assessment records cannot be trusted yet.	High (confirmed in part)
Availability	File shares, portal materials, submissions and the contact list are unavailable. The examination is at risk.	Critical (confirmed)

Response priorities (in order)

1. **Stop the spread.** Isolate FIN-PC07 and FS01 and disable svc_backup and the finance account (E03, E06).
2. **Protect the backups.** Isolate BAK01 and secure the Friday disconnected backup, because it is probably our only clean recovery point (E03, E05).
3. **Preserve evidence** while containing, and start an incident and decision log.
4. **Set up safe communication.** Use phones and a secondary channel because the contact list and email are unreliable (E08).
5. **Decide the examination by 10:00.** Do not reopen the portal until a validated clean restore exists. Prepare postponement notices.
6. **Scope the theft** and involve legal and privacy advice early (E04).

Task 1d. My 5 Priority Investigation Questions

	Question	Check that can resolve it	Finding that would change severity or scope
Q1	Did malicious code run on FIN-PC07, and was that the entry point?	EDR process tree, mail trace and headers, sandbox test of the attachment (planned), disk and memory image, interview with the finance officer.	If the attachment was harmless, the entry point is identity compromise, so cloud and mailbox scope grows. If the same file ran on other hosts, scope widens to those hosts.
Q2	Was the 01:15 sign-in an attacker, and was MFA bypassed?	Entra sign-in and audit logs (IP, device, MFA result, token use), mailbox rules and OAuth app consents, interview.	Confirmed attacker with mailbox access moves confidentiality from suspected to probable, widens scope to email and cloud data, and starts the reporting assessment.
Q3	Was svc_backup abused, and have backups been changed or deleted?	Windows security logs on FS01 and BAK01 (logon type, source IP), backup console audit, retention settings, deleted restore points.	If BAK01 is tampered with, network backups are untrusted. Recovery depends on the Friday copy (about 64 hours of potential data loss) and recovery time grows. Severity stays Critical.
Q4	What was inside the 1.2 GB upload?	Proxy and firewall logs, DNS, EDR file-read events, file-system timeline of FIN-PC07, destination reputation.	If learner or finance records are inside, the incident becomes a confirmed personal data breach and the formal notification process starts. If it was payroll files only, the affected group shrinks to staff.
Q5	Are other systems (LMS01 and servers without EDR) infected?	Indicator sweep, scheduled tasks and new services, admin logon review, manual checks on servers without EDR.	Any further infected server raises scope and lengthens recovery. A clean LMS01 shortens the path to restoring the examination.

All Required outputs for Task 1 Completed: incident timeline (1a), severity assessment (1b and 1c), investigation priorities (1d).

Task 2. Incident Response Plan and Team Responsibilities

Task 2a. Policy and Plan Outline

NORTHBRIDGE SKILLS INSTITUTE

OPERATIONAL INCIDENT RESPONSE POLICY & INCIDENT ACTION PLAN (IAP)

Active Incident Directive: Day 0 Multi-System Ransomware & Data Exfiltration Event

DOCUMENT CONTROL & VERSION HISTORY

Version	Date	Author / Title	Description of Operational Changes	Approved By
1.0 (Active)	Day 0, 08:45 WAT	Incident Response Lead/ Lead Security Analyst	Emergency Incident Action Plan (IAP) formulation following confirmed file encryption (.locked) on FS01 and unauthorized svc_backup administrative activity (E03, E06).	Head of IT / CTO

1. MISSION

The immediate mission of Northbridge Skills Institute during this active crisis is to rapidly contain the multi-system ransomware outbreak affecting FIN-PC07 and FS01, prevent lateral movement to network backups (BAK01) and identity infrastructure (Microsoft 365), investigate suspected data exfiltration (E04), and maintain institutional continuity, specifically safeguarding the online examination for 100 learners scheduled for 11:00 WAT on Day 0.

2. OBJECTIVES

To fulfill this mission under strict time constraints, this Incident Action Plan establishes six prioritized operational objectives:

a. **Immediate Containment (08:45 – 09:15 WAT):** Network-isolate compromised assets (FIN-PC07, FS01) and preserve offline backup integrity (BAK01 / disconnected media) to halt threat propagation.
b. **Exam Safeguarding & Business Continuity (08:45 – 09:30 WAT):** Assess LMS01 integrity and execute an out-of-band assessment strategy for the 100 learners before the 11:00 WAT exam deadline.
c. **Forensic Analysis & Scope Determination (09:00 – 12:00 WAT):** Investigate svc_backup credential abuse, the 1.2 GB HTTPS data transfer, and determine if learner or staff personal data was exfiltrated.
d. **Out-of-Band Communication (Continuous):** Establish secure, untrusted-network communication channels for staff, learners, and leadership while corporate email and FS01 files are untrusted or inaccessible.
e. **Controlled Recovery:** Restore damaged systems strictly from validated, uncorrupted offline backups following rigorous clean-room verification and Business Owner approval.
f. **Post-Incident Lessons-Learned:** Conduct a formal post-incident review within two weeks of closure to remediate architectural vulnerabilities (e.g., svc_backup over-privileging, lack of server EDR).

3. SCOPE

This Incident Action Plan applies to all technological assets, personnel, and data assets within Northbridge Skills Institute:

- **In-Scope Systems & Infrastructure:**
  - FIN-PC07 (Finance Workstation – Initial Compromise & Exfiltration Point)
  - FS01 (Shared File Server – Encrypted Shared Files)
  - LMS01 (Learning Management Portal – Exam Dependency on FS01)
  - BAK01 (Network Backup Repository – Suspicious svc_backup Activity)
  - Microsoft 365 (Identity & Email – Anomaly IP Sign-In)
- **In-Scope Data:** All 1,800 learner records, 90 staff HR files, admission documents, assessment banks, and institutional finance records.
- **In-Scope Personnel:** CSIRT members, 3 IT staff, 1 Security Analyst, executive leadership, and the 100 exam candidates.

4. INCIDENT DECLARATION

An observable **event** was escalated and formally declared a **CRITICAL INCIDENT** at 08:45 WAT on Day 0 by the Security Analyst/ Incident Response Lead based on verified multi-system compromise:

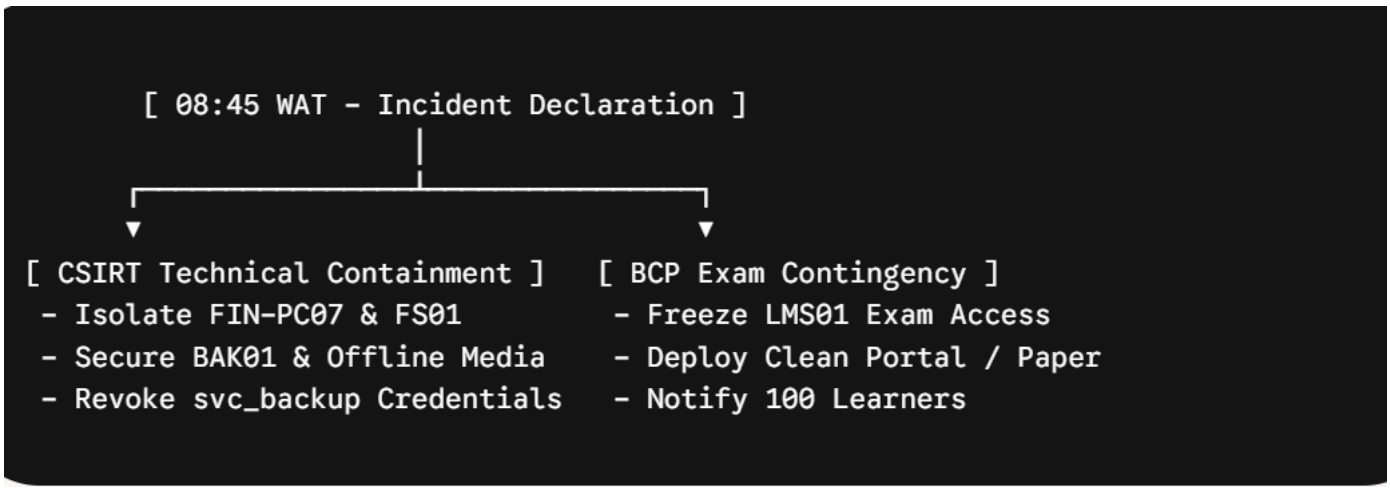
a. **Primary Triggers:** Mass file encryption (.locked files and ransom note on FS01), unauthorized out-of-hours logon by svc_backup to FS01 and BAK01, 1.2 GB external data transfer from FIN-PC07, and loss of operational access to FS01 dependencies.

b. **Declaration Authority:** While primary declaration authority normally rests with the Incident Manager, the Lead Security Analyst exercised emergency fail-safe authority at 08:45 WAT to declare the Critical Incident, assume Incident Command, and immediately activate full CSIRT containment protocols.

5. ACTIVATION AND ESCALATION RULES

Due to the active ransomware deployment and potential backup compromise, this incident is classified as **CRITICAL SEVERITY**.

- **Activation Actions (Executed Immediately at 08:45 WAT):**
  - Full CSIRT activated; CTO briefed within 15 minutes.
  - External Incident Response retainer firm and Legal Counsel engaged immediately for forensics and regulatory assessment.
  - Business Continuity Coordinator alerted to manage the 11:00 WAT exam contingency.



Automatic Escalation Triggers

The incident automatically escalates to maximum executive involvement and mandatory regulatory disclosure if:

a. Threat actor activity is confirmed on BAK01 or offline backup media.
b. Forensics confirms that the 1.2 GB exfiltrated data contains Personally Identifiable Information (PII) or financial records.
c. Threat actors make direct contact or extortion demands.
d. Active containment is not achieved within 4 hours of declaration (by 12:45 WAT).

6. AUTHORITY TO ISOLATE SYSTEMS

To stop lateral spread without delay:

a. **Emergency Isolation Power:** The Incident Manager and Lead Security Analyst are pre-authorized to immediately sever any endpoint, server, service, or user account from the network upon detecting indicators of compromise.
b. **Immediate Isolation Actions:**
    - **Network Disconnect:** Physically and logically isolate FIN-PC07, FS01, and BAK01 from the internal network and internet.
    - **Credential Revocation:** Immediately disable the svc_backup service account and force a password/MFA reset across all privileged accounts and the compromised finance officer account in Microsoft 365.
c. **Notification Rule:** The CTO and Business Owner must be notified concurrently with isolation, but isolation shall **never** be delayed to wait for administrative approval.

7. DOCUMENTATION REQUIREMENTS

Since FS01 is inaccessible and internal email is unverified, all operational logging must occur **out-of-band**:

a. **Physical & Secure Out-of-Band Logs:** Incident logs must be recorded in physical notebooks and replicated to an isolated, encrypted workspace (outside M365 and FS01).
b. **Required Registers:**
    1. **Master Chronological Incident Log:** Record all actions, observations, and findings in West Africa Time (WAT).
    2. **Decision Log:** Document operational decisions, trade-offs (e.g., exam delay vs. containment), and executive sign-offs.
    3. **Chain-of-Custody Register:** Maintain strict forensic tracking for volatile RAM captures, disk images of FIN-PC07 and FS01, proxy logs (E04), and M365 audit exports (E02).

8. PLAN REVIEW AND MAINTENANCE

a. **Post-Incident Lessons-Learned Review:** A mandatory debrief must be conducted within two (2) weeks of full incident closure.
b. **Policy Remediation:** This plan and the overarching IR framework will be updated based on findings, specifically addressing backup immutability, server EDR deployment, and out-of-band communication readiness.

9. ALIGNMENT WITH BUSINESS CONTINUITY PLAN (BCP)

Incident Response (IR) and Business Continuity (BC) operate in parallel during this crisis:

1. **Immediate Exam Decision (Target: 11:00 WAT Exam for 100 Learners):**
    - *Technical Reality:* LMS01 depends on FS01, which is encrypted and unauthenticated.
    - *BCP Action:* The Business Continuity Coordinator, in agreement with the Business Owner (Academic Head), executes the exam contingency plan before 09:30 WAT, either deploying an isolated clean-room assessment instance or postponing/shifting to an offline paper-based assessment.
2. **RTO and RPO Alignment:**

- *Recovery Point Objective (RPO):* The last known clean offline backup is Friday 17:00 WAT (Day -3). Data created between Friday evening and Monday morning faces loss; recovery validation must confirm data integrity.
- *Recovery Time Objective (RTO):* Systems will remain isolated until full forensic clearance is achieved.

3. **Return-to-Service Authority:** The IT team provides technical readiness certification, but **only the Business Owner** holds the authority to approve bringing LMS01 and FS01 back into live production.

10. EXECUTIVE APPROVAL AND ACKNOWLEDGMENT

By signing below, executive leadership formally ratifies this Operational Incident Action Plan, authorizing emergency containment, system isolation, and business continuity protocols for the Day 0 incident.

Chioma Onyekelu Oct 15, 2026, 08:45 am WAT

Incident Response Lead & Security Analyst

(Incident Manager & Plan Author)

Mr. Guy Oct 17, 2026, 08:55am WAT

Business Owner / Academic Head

Approved and Executed by:

Mr. Paul Oct 15, 2026, 09:00 WAT

Principal / Chief Technology Officer

Task 2b. CSIRT Structure

	Role	Who (fictional)	Main duties
1	**Incident Manager**	IR Lead (Chioma Onyekelu)	Declares the incident, leads decisions, manages priorities, briefs executives.
2	**Security Analyst**	Northbridge security analyst	Triage, log and EDR analysis, indicator sweeps, containment actions.
3	**Forensics Specialist**	External firm on retainer, with a trained IT staff member as backup	Collects and preserves evidence, analyses malware, maintains chain of custody.
4	**IT Operations Lead**	Senior IT staff member	Executes isolation, account resets, rebuilds, backups and restoration.
5	**Business Owner**	Director of Examinations and Learning (Mr Guy)	Sets service priorities, decides on examinations, approves return to service.
6	**Legal and Privacy Adviser**	External counsel and Data Protection Officer	Assesses reporting duties, advises on evidence, ransom and contracts.
7	**Communications Lead**	Registrar or marketing manager	Writes and sends staff, learner and media messages after approval.
8	**Executive Sponsor**	Principal/CTO	Approves high-impact decisions (spending, ransom position, external statements).
9	**Scribe**	Administrative officer	Keeps the incident log and decision log.

Getting extra support with a small team. Northbridge has **three IT staff and one analyst**, so it cannot cover a 24/7 Critical incident alone.

The plan therefore includes: (a) a pre-contracted external IR and forensics retainer with a stated call-out time; (b) a managed detection service or analyst cover outside office hours; (c) vendor emergency contacts for Microsoft, the backup supplier and the internet provider; (d) the cyber insurer's response hotline; (e) the national CERT and a sector information-sharing group; and (f) a mutual aid agreement with a partner institution.

External support is requested when any of these occur: a Critical declaration, suspected data theft, containment not achieved in 4 hours, or a task beyond internal skills such as forensic imaging. Contracts, non-disclosure agreements and approvals are agreed in advance so that no procurement delay occurs.

Task 2c. RACI Matrix

Key: **R** = Responsible (does the work), **A** = Accountable (one person who owns the result and approves), **C** = Consulted (gives input before decisions), **I** = Informed (told after). **A/R** means the same role does the work and is accountable. A dash means not involved. Every row has exactly one A.

Roles: IM = Incident Manager, SA = Security Analyst, FS = Forensics Specialist, IT = IT Operations Lead, BO = Business Owner, LP = Legal and Privacy Adviser, CL = Communications Lead, ES = Executive Sponsor.

Activity	IM	SA	FS	IT	BO	LP	CL	ES
1. Detection	A	R	I	C	I	-	-	-
2. Analysis	A	R	C	C	I	I	I	I
3. Containment	A/R	R	C	R	C	I	I	I
4. Evidence handling	A	C	R	C	-	C	-	I
5. Stakeholder communication	R	C	I	I	C	C	R	A
6. Assessment of reporting obligations	C	C	C	I	C	R	I	A
7. Restoration approval	R	C	C	R	A	I	I	I
8. Closure and review	R	C	C	C	C	C	C	A

The RACI I adopted followed the pattern on our training slide note page 15 (for example the Incident Manager is accountable for detection, analysis and containment, and Forensics is responsible for evidence). I made the Executive Sponsor accountable for external communication, reporting decisions and closure, because these carry legal and reputational risk. The Business Owner is accountable for restoration approval so that the service owner, not IT, accepts the risk of going live.

Task 2d. Preparation Improvements and Readiness Checklist

	Improvement	Owner	Resources needed	How readiness is checked
1	**Backup readiness:** immutable and offline copies, separate backup credentials (not the	IT Operations Lead	Immutable (write-once) storage or offline media rotation, a separate backup admin	Quarterly restoration test of FS01 and LMS01 with recorded restore time and data age against RTO and RPO. Monthly

	Improvement	Owner	Resources needed	How readiness is checked
	all-powerful svc_backup), written restore procedure.		account with MFA, a test environment, staff time.	backup verification report signed by the Business Owner.
2	**Accessible incident contact list** and out-of-band communication: printed copies, phone copies for all CSIRT members, a secondary secure messaging group, vendor emergency numbers.	Incident Manager	Printing, secure messaging app, a mailbox outside the main tenant, quarterly admin time.	Quarterly call-tree test: at least 90% of the CSIRT reached within 30 minutes. Review the list for changes monthly.
3	**Tools:** EDR on all servers (FS01, LMS01, BAK01), central log collection and alerting.	Security Analyst	EDR licences for servers, log storage, managed detection service for out-of-hours cover.	Monthly coverage report must show 100% of servers reporting. A harmless simulated detection is raised each quarter and the alert time is measured.
4	**Identity security:** enforce MFA for all staff and admins, restrict service accounts, review admin rights, conditional access.	IT Operations Lead	Microsoft 365 licences with conditional access, access review time.	Monthly report: MFA coverage 100% for admins and finance. Quarterly access review. No service account with interactive logon.
5	**Training and exercises:** phishing awareness for all 90 staff, role-specific CSIRT training, two tabletop exercises a year.	Incident Manager	Training platform, facilitator time, exercise scenarios.	Phishing simulation click rate and reporting rate tracked each quarter. CSIRT attendance 100%. Written exercise report with actions.
6	**Secure forensics kit and retainer:** evidence bags, write blockers, encrypted drives, custody forms, signed IR retainer.	Executive Sponsor and Forensics Specialist	Budget for retainer, kit purchase, secure safe.	Yearly retainer test call. Quarterly kit inventory check.

All Required outputs for Task 2 Completed: policy and plan outline (2a), team structure (2b), RACI matrix (2c), readiness checklist (2d).

Part 2: Response Operations and Communication

Task 3: Response Playbook and Evidence Preservation (25 marks)

a. Create a playbook containing at least ten ordered actions for the first 60 minutes after 08:45 and the remainder of the first 24 hours. Use columns for time or stage, action, owner, required approval, evidence to retain, and completion check.
b. Cover short term containment, investigation, longer term containment, eradication, recovery, and closure. Address affected endpoints, privileged and cloud accounts, the shared server, suspicious transfers, and backup access. Explain how you will check for broader compromise.
c. Justify two difficult decisions: containment while preserving useful evidence, and restoring examination access while backup safety is uncertain. Explain when immediate isolation is necessary and how you will document any evidence loss or operational impact.
d. Create an evidence register for at least four relevant items. Record ID, source, proposed collection method, collector role, date and time with timezone, integrity check, secure storage, and custody transfers. Describe access restrictions. Use planned or not yet collected where appropriate; do not invent hashes or claim acquisitions you did not perform.
e. Describe how you will remove persistence, address the likely entry point, and secure compromised credentials. Set recommended restoration order, recovery targets, and acceptable data loss. Explain how you will select and validate a backup, restore in a controlled environment, check data integrity, and monitor for recurrence before the business owner approves service return.

Required outputs: playbook, evidence register with custody arrangements, and recovery acceptance criteria.

Task 4: Communication and Escalation (10 marks)

a. Create a communication matrix for at least six stakeholder groups. Record trigger, message owner, channel, approver, and update frequency. Include learners, management, IT or security staff, a relevant service provider, and legal or privacy advisers. Provide an alternative channel if corporate email is unsafe or unavailable.
b. Draft a 150 to 200 word executive briefing with confirmed impact, uncertainty, decisions requiring approval, and the next update time. Draft a separate 100 to 150 word learner notice with practical instructions and the status of the examination.
c. Explain how legal or privacy advisers will assess notification obligations and confirm the relevant recipients and deadlines. Distinguish operational notices from any formal breach notification. If you assert a legal deadline, identify the jurisdiction and cite an authoritative source.

Required outputs: communication matrix, executive briefing, learner notice, and escalation rules.

ANSWERS

Task 3. Response Playbook and Evidence Preservation

Task 3a. Response Playbook (T0= Day 0, 8:45 WAT)

All actions are planned. Evidence IDs (E01 to E08) refer to the initial evidence pack. "IM" is the Incident Manager. Evidence references EV-01 to EV-06 are in section 3d.

Stage A: Short-term containment (first 60 minutes)

#	Time	Action	Owner	Approval	Evidence to retain	Completion check
1	08:45 to 08:50	**Declare a Critical Incident.** Open the incident log and decision log on paper and in a workspace outside FS01. Record time of declaration.	IM	Executive Sponsor/ CTO informed by phone (no wait)	E01 to E08 copies, declaration time	Declaration time is in the log and the Principal confirms by phone.
2	08:50 to 09:00	**Activate the CSIRT by phone** (staff phones work, E08). Start a phone bridge. Call the external IR and forensics firm.	IM	Executive Sponsor/CTO approves retainer call-out	Call log, names and times	All core roles are on the bridge by 09:00.
3	08:50 to 09:00	**Isolate FIN-PC07 and FS01** from the network using EDR network containment or switch port or VLAN quarantine. Do **not** power off. Photograph the ransom note and screen.	IT Operations Lead with Security Analyst	Pre-approved in the plan (IM)	EDR containment log, screenshots, photographs	Hosts show "contained" and cannot reach the network. Shares on FS01 are intentionally offline.
4	08:55 to 09:10	**Secure privileged and cloud accounts.** Disable svc_backup and the finance officer's account, revoke Microsoft 365 sessions and tokens, block the unfamiliar IP (E02, E03), remove admin rights not needed today. First	IT Operations Lead and Security Analyst	IM	Exported Entra sign-in and audit logs (EV-03)	Accounts show disabled, sign-in log shows no active sessions.

#	Time	Action	Owner	Approval	Evidence to retain	Completion check
		export the sign-in and audit logs (read-only).				
5	09:00 to 09:15	**Protect backups.** Take BAK01 off the network, pause backup and deletion jobs, lock away the Friday disconnected backup media, and do not mount any network backup on a production system (E03, E05).	IT Operations Lead	IM	Backup console job list and retention settings, console audit log (EV-05)	BAK01 cannot be reached. Friday media is tagged, locked and logged.
6	09:05 to 09:20	**Block the suspicious transfer path.** Block the unfamiliar cloud storage destination and attacker IPs at the proxy and firewall (E04). Preserve the proxy logs first.	Security Analyst	IM	Proxy and firewall logs, rule change record (EV-04)	Test shows the destination is blocked. No new uploads are seen.
7	09:10 to 09:30	**Start evidence acquisition:** memory capture then forensic image of FIN-PC07, volatile data and logs from FS01, email and attachment sample (E01).	Forensics Specialist with Security Analyst as witness	IM	EV-01, EV-02, EV-06 per register	Each item is listed with time and custody form signed.
8	09:15 to 09:30	**Set up safe communication.** Treat corporate email as untrusted (E08). Use phone calls, SMS and a secondary secure messaging group with verified numbers. Agree a code word and call-back rule.	Communications Lead and IM	IM	Channel list and member list	Every CSIRT member confirms through the secondary channel.
9	09:30 to 09:45	**Scope check across the estate.** Sweep all workstations with EDR indicators. Manually check LMS01, BAK01 and other servers without EDR (new accounts, scheduled tasks,	Security Analyst	IM	Query outputs and screenshots	Every host is listed as clean, suspicious or unknown. No new encrypted host is found.

#	Time	Action	Owner	Approval	Evidence to retain	Completion check
		new services, admin logons). Review mailbox rules and app consents in Microsoft 365.				
10	09:45 to 10:00	**Examination decision gate.** Check LMS01 read-only in isolation. Apply the rule in section 3b. Brief the Business Owner and Principal. Comms issue the learner notice by 10:00.	Business Owner (decides) with IM	Executive Sponsor	Decision log entry with rationale	Decision and notice time are recorded.
11	10:00 to 10:30	**Brief legal and privacy adviser.** Record the time the institution became aware of a possible breach, so the reporting clock is documented (section 4.3). Insurer notified.	IM	Executive Sponsor	Notes of the call, awareness time	Legal adviser has the facts and a first view is recorded.

Stage B: Investigation and longer-term containment (hours 1 to 8)

	Time	**Action**	**Owner**	**Approval**	**Evidence to retain**	**Completion check**
12	10:00 to 14:00	**Investigate:** answer Q1 to Q5 (Task 1). Identify the entry point, attacker timeline, malware family (sandbox the sample) and contents of the 1.2 GB upload (E04).	Security Analyst and Forensics Specialist	IM	Analysis notes, sample hash (to be recorded), timeline	Each question has a written answer with its supporting evidence.
13	10:30 to 13:00	**Longer-term containment:** reset passwords and rotate secrets for all admin and service accounts, enforce MFA, block RDP and SMB between segments, move servers to a restricted VLAN, install EDR on servers once forensics agrees.	IT Operations Lead	IM	Change tickets, reset list	The reset list is complete and server EDR coverage shows 100%.

Stage C: Eradication, recovery and closure (hours 8 to 24 and after)

#	Time	Action	Owner	Approval	Evidence to retain	Completion check
14	13:00 to 18:00	**Eradicate:** remove persistence and close the entry point . Rebuild FIN-PC07 and FS01 from clean images rather than "cleaning" them.	IT Operations Lead and Security Analyst	IM	List of persistence found and removed	Rescan with two different tools and a hunt show no indicators.
15	15:00 to 22:00	**Select and validate a backup, then restore** into an isolated clean environment (section 3.5).	IT Operations Lead and Forensics Specialist	IM, then Business Owner	Validation report, restore log	Recovery acceptance criteria 1 to 6 (section 3.6) are met.
16	22:00 to Day 1 08:00	**Test the examination** with test accounts, then decide on phased return and enhanced monitoring.	Business Owner (decides) with Security Analyst	Business Owner and Executive Sponsor	Test results, written approval	Acceptance criteria 1 to 9 are signed.
17	Day 1 and after	**Closure:** status report, evidence retained, lessons-learned review within two weeks (ICDFA, slide 12), plan updated.	IM	Executive Sponsor	Final report, action list	Executive Sponsor signs closure after all actions are evidenced.

Task 3b. Checking for broader Compromise

How I will check for broader compromise. The earliest evidence is E01 on Day -1, so I would look back at least 30 days. I would:

(a) sweep all endpoints and servers for the indicators found on FIN-PC07;

(b) review authentication logs for svc_backup and the finance account across all systems;

(c) review Microsoft 365 audit logs for forwarding rules, new app consents and new MFA devices;

(d) search proxy and DNS logs for any other host contacting the same destination as E04;

(e) check servers without EDR by hand;

(f) look for new accounts, scheduled tasks, services and group membership changes;

(g) check network flows for sideways movement over SMB and RDP; and

(h) compare the state of LMS01 with a known-good baseline.

Task 3c. Two Difficult Decisions

Decision 1: Contain quickly while keeping useful evidence.

Decision: I isolate FIN-PC07 and FS01 immediately but do not switch them off. After isolation I would capture memory and logs.

When immediate isolation is necessary: when there is active encryption, active use of privileged credentials, ongoing data transfer, or a threat to backups. All four are present here (E03, E04, E05, E06). Each minute of delay can encrypt more files, so I would not wait to finish memory capture first. Powering off is a last resort, only if a host cannot be disconnected (this is consistent with CISA, n.d.), because it destroys memory evidence.

Evidence loss and operational impact*:* some live network connections and short-lived memory data may be lost. I would record the isolation time, who authorised it, the steps taken, what was captured and what could not be captured. I would also log the business impact: FS01 shares are offline for 90 staff, the portal cannot serve materials, and the examination is at risk. If a host were quiet and not spreading, I would allow up to 15 to 30 minutes to capture memory first.

Decision 2: Restoring examination access while backup safety is uncertain.

Options: (a) reopen the production portal from the Day 0 02:00 backup; (b) postpone the examination until everything is restored; (c) run the examination from a clean restore built from the safest source.

Decision*:* I will **not** reopen the production portal from an unvalidated backup. The decision gate is 10:00, with a final go or no-go at 10:15. The examination goes ahead only if a clean restore (preferably from the Friday disconnected backup) has passed validation, with credentials reset and a successful test login, content open and test submission. Otherwise, the examination is postponed to the earliest safe slot.

Reasoning*:* the 02:00 backup was taken after the suspicious sign-in and administrator logons (E02, E03), so it is the least trusted. Restoring bad data could reinfect the system and damage assessment records for 100 learners, which cannot be repaired easily. A short delay can be recovered. The Business Owner makes the decision as accountable owner of the service, with the Executive Sponsor informed. The accepted cost is lost work since Friday 17:00 and a delayed examination.

Task 3d. Evidence Register

All entries are **planned or not yet collected**. No hashes are invented. Hashes will be calculated at acquisition and recorded here.

ID	Source	Proposed collection method	Collector or role	Date and time (WAT)	Integrity check	Secure storage	Custody transfers
EV-01	FIN-PC07 memory and disk (E01, E04, E06)	Live memory capture through EDR or forensic tool, then forensic disk image using a write blocker.	Forensics Specialist (witness: Security Analyst)	Planned: Day 0, from about 09:10 WAT. Actual time to be recorded.	SHA-256 of image to be calculated at acquisition and re-checked on the working copy. Not yet collected.	Encrypted drive in a sealed evidence bag in a locked safe. Working copy only on the forensic workstation.	Forensics Specialist to Evidence Custodian (IM) to external lab if engaged. Each move is signed on the custody form.
EV-02	FS01 event logs, ransom note, sample .locked files (E06)	Export Security and System logs. Copy the note and three sample files. Capture volatile data if the host is still on.	Security Analyst or Forensics Specialist	Planned: Day 0, from about 09:15 WAT.	SHA-256 of each export to be calculated at collection. Not yet collected.	Encrypted evidence drive in a safe, separate from FS01.	Collector to Evidence Custodian. Logged on custody form.
EV-03	Microsoft 365 and Entra sign-in and audit logs, mailbox audit for the finance officer (E02)	Read-only export from the admin portal in CSV or JSON.	Security Analyst (M365 admin role)	Planned: Day 0, from about 08:55 WAT.	Hash of each export. Second copy kept read-only. Not yet collected.	Encrypted evidence store outside the Northbridge network.	Security Analyst to Evidence Custodian.
EV-04	Proxy, firewall and DNS logs for	Export from proxy and	Security Analyst	Planned: Day 0, from about	Hash of each export. Not	Encrypted evidence store.	Security Analyst to Evidence Custodian.

ID	Source	Proposed collection method	Collect or role	Date and time (WAT)	Integrity check	Secure storage	Custody transfers
	FIN-PC07, Day -1 to Day 0 (E04)	firewall consoles.		09:05 WAT.	yet collected.		
EV-05	BAK01 logs, backup console settings and job history, and the Friday disconnected backup media (E03, E05)	Screenshots and console exports. For the media: record label and serial number, keep write-protected, do not mount on production.	IT Operations Lead (witness: Forensics Specialist)	Planned: Day 0, from about 09:00 WAT.	Hash of exports. Media sealed with a tamper-evident label. Not yet collected.	Locked safe for the media. Encrypted store for exports.	IT Operations Lead to Evidence Custodian to Forensics Specialist when imaged.
EV-06	Original payroll email with headers and attachment (E01)	Export the message from the mail trace and quarantine the attachment copy. Analyse only in a sandbox.	Security Analyst	Planned: Day 0, from about 09:20 WAT.	Hash of the .eml file and attachment. Not yet collected.	Encrypted evidence store.	Security Analyst to Evidence Custodian.

Access restrictions. Only the Evidence Custodian (Incident Manager), the Forensics Specialist and named analysts may handle originals, using a two-person rule. Nobody works on original evidence. Evidence is stored away from the affected network. Every access is written in the custody log with date, time (WAT), name, reason and signature. Legal counsel may view copies on request through the Evidence Custodian.

Task 3e. Remove Persistence, Setting Restoration Order and Validating Backup

Remove Persistence, Close the entry point, Secure Credentials

Persistence. From the findings, I would remove malicious scheduled tasks, services, registry run keys, startup items and rogue local or cloud accounts. In Microsoft 365, I would remove forwarding rules, unknown app consents and unknown MFA devices. I would rebuild FIN-PC07 and FS01 from clean images instead of trying to clean them. I would verify removal with more than one scanning tool and a final hunt (ICDFA, slide 11).

Entry point. The likely route is the payroll attachment (E01) and credential theft (E02), to be confirmed by Q1 and Q2. I would block risky attachment types and macros, turn on email attachment scanning, confirm EDR blocks the sample, patch any exploited weakness, train finance staff and move finance users to phishing-resistant MFA (ICDFA, slide 11).

Credentials. I would reset the finance officer's password and revoke all tokens. I would replace svc_backup with a least-privileged, non-interactive account with a long random secret, and rotate every secret that was stored on FS01 or in scripts. I reset all administrator passwords. If an on-premises directory is in use and shows signs of compromise, I would follow the directory's full recovery procedure for its core credentials. I enforce MFA for all users (CISA, n.d.).

Restoration order, recovery targets and backup validation

Restoration order

1. Secured identity (Microsoft 365 controls) and a clean network segment with security tools.
2. A new or rebuilt backup repository (do not reuse BAK01 until it is cleared).
3. FS01, restoring only the files needed for the portal first, because LMS01 depends on FS01 (scenario).
4. LMS01 (the portal) and the examination content.
5. Finance (FIN-PC07 rebuilt) and other business files.
6. Remaining staff devices and lower-priority services.

Recovery targets (proposed by me as the Incident Response Lead, to be confirmed by the Business Owner).

Item	Target
Minimum examination service (LMS01 plus examination content)	Within 12 hours of containment, with a clean-room restore
FS01 core shares	Within 24 hours
Full restoration of all services	Within 3 to 7 days
Acceptable data loss (RPO) for this incident	Up to the Friday 17:00 backup, about 64 hours, if network backups fail validation. Lost work is re-created.
Target RPO after improvement	24 hours or less for learning and assessment data

How I would select and validate a backup as the Incident Response Lead. I would:

1. **List candidates:** (a) the Friday 17:00 Day -3 disconnected backup, (b) network backups from Day -2 and Day -1, and (c) the Day 0 02:00 network backup (E05).
2. **Select:** choose the most recent backup that is older than the first evidence of compromise (E01, Day -1 16:40) and passes validation. The disconnected Friday backup is the baseline. Anything later is used only after it also passes validation.

3. **Validate:** check media integrity, mount read-only in an isolated sandbox, scan with more than one engine, search for attacker artefacts (new accounts, tasks, tools, .locked files), open sample files and test database consistency for LMS01.
4. **Restore in a controlled environment:** an isolated network with no internet. Build servers from known-good images, patch them, install EDR first and reset credentials. Restore data rather than whole system images wherever possible, so persistence is not copied back.
5. **Check data integrity:** compare file counts and sizes with expectations, compare hashes of known documents, run database checks, and have the Business Owner review a sample of 20 records. Run a functional test: login, open materials, submit, store a result.
6. **Monitor before return:** run the restored service in isolation for a minimum observation period (target 2 to 4 hours for the examination, longer for full services). After return, run enhanced monitoring for 14 days with EDR, sign-in and outbound traffic alerts.
7. **Approval:** the Business Owner approves the return only after all criteria below are met.

Recovery acceptance criteria

1. The source backup is validated (integrity, multi-engine scan, no attacker artefacts).
2. Restored servers were built from clean, patched images, with EDR installed and reporting.
3. All privileged and service credentials are rotated and MFA is enforced.
4. Integrity checks pass: counts, hashes, database checks and the Business Owner's sample review.
5. No indicator alerts and no unexplained outbound traffic during the observation period.
6. A functional examination test with test accounts succeeds from login to stored result.
7. A rollback point and a fresh backup of the restored state exist.
8. The Business Owner gives written approval after the Incident Manager's recommendation. Legal advice and the communications plan are ready.
9. Enhanced monitoring for 14 days is in place and assigned.

All Required outputs for Task 3 Completed: playbook (3a), evidence register with custody arrangements (3d), recovery acceptance criteria (3c).

Task 4. Communication and Escalation

Task 4a. Communication Matrix

Corporate email is treated as untrusted until verified (E08). Every message is sent from the primary channel shown, with the alternative channel as a back-up.

Stakeholder	Trigger	Message owner	Channel (primary / alternative)	Approver	Update frequency
Executive management (Principal)	Critical declaration (about 08:50).	Incident Manager	Phone call / secure messaging group	Incident Manager	Hourly for the first 8 hours, then every 4 hours.
IT and security staff and CSIRT	CSIRT activation.	Incident Manager	Phone bridge / secure messaging group	Incident Manager	Every 30 minutes for the first 4 hours, then hourly.
All staff (90)	Containment confirmed (about 09:30). Instructions: do not open the infected files, do not restart devices, do not use email for incident talk, report odd messages.	Communications Lead	SMS and phone broadcast / briefing at reception and notice board	Executive Sponsor	Twice daily until recovery.
Learners (1,800; 100 sitting the examination)	Examination decision gate (10:00) or any service change.	Communications Lead	SMS and banner on the portal login page (it still loads, E07) / website notice and social media	Executive Sponsor and Business Owner	First notice by 10:00, next at 10:30, then at least every 4 hours and at 17:00 daily.
Service providers (Microsoft support, backup supplier, internet	Need for log retention, blocking, restoration help or forensics.	IT Operations Lead (Incident Manager for the IR firm)	Phone and vendor support portal / named account manager by phone	Incident Manager	Hourly with the IR firm, others as needed.

Stakeholder	Trigger	Message owner	Channel (primary / alternative)	Approver	Update frequency
provider, external IR firm)					
Legal and privacy advisers (counsel and Data Protection Officer)	Declaration, and again if theft is suspected (E04) or confirmed.	Incident Manager	Phone call / secure messaging	Incident Manager	At each milestone and at least daily.
Regulator (Nigeria Data Protection Commission) and police	Only when legal advice says a report is needed.	Legal and Privacy Adviser	Official channel chosen by counsel / alternative clean mailbox	Executive Sponsor	Initial report within the legal time limit, then updates as required.
Media and public	Journalist enquiry or social media claim.	Communications Lead	Holding statement through the official website and social page / spokesperson call-backs	Executive Sponsor with Legal Adviser	As needed, never ahead of confirmed facts.
Cyber insurer	Critical declaration.	Executive Sponsor	Insurer hotline / broker	Executive Sponsor	Daily.

Alternative channels if corporate email is unsafe or unavailable (E08): phone calls and SMS using the printed and phone-held contact list; a secure messaging group with numbers verified by a call-back; a mailbox outside the compromised tenant, set up for incident use; the portal login banner, website notice and a staff notice board. To stop impersonation (an attacker could write in the Principal's name), important requests are confirmed by a call-back to a known number.

Task 4bi. Executive Briefing

To: Principal | **From:** Incident Manager | **Time:** Day 0, 09:15 WAT | **Channel:** phone and secure messaging

Confirmed: Northbridge is facing a Critical ransomware incident. The finance workstation (FIN-PC07) and the shared file server (FS01) show mass file encryption and a ransom note (E06). The learning portal loads, but learners cannot open materials or submit assessments (E07). The incident contact list is inaccessible (E08). Both systems are isolated, and the suspect accounts are disabled.

Uncertain: how the attacker entered, whether learner or finance data was stolen (1.2 GB left FIN-PC07, E04), and whether network backups are safe (E03, E05). The attacker's identity is not established.

Decisions needed by 09:45: (1) activate the external forensics and incident response retainer; (2) approve putting the 11:00 examination for 100 learners on hold unless a validated clean restore is ready by 10:15, because restoring from an untested backup could reinfect systems and damage assessment records; (3) authorise staff and learner notices; (4) appoint legal counsel to assess notification duties; (5) confirm that no ransom contact occurs without your approval.

Next update: 10:15 WAT, then hourly.

Task 4bii. Learners Notice

Subject: Important notice: examination and learning portal

Dear learner,

Northbridge Skills Institute is dealing with a technical security incident affecting some of our systems. We are investigating with specialist support.

Examination: today's 11:00 examination is on hold. We will confirm by 10:30 whether it will take place today or be rescheduled. No learner will be penalised.

What to do now:

- Do not open emails or links about this incident unless they come from the official channels below.
- Never share your password, and never pay anyone who contacts you.
- Do not keep trying to log in; portal materials are currently unavailable.
- Check the portal login-page banner and our official SMS for updates.

Report suspicious messages to support@northbridge.example. Our next update is at 13:00 today.

Northbridge Communications Team

Task 4ci. How Legal and Privacy Advisers Assess Notification Duties

The Legal and Privacy Adviser leads this work, and the Executive Sponsor decides. The steps are:

1. **Confirm the facts.** The Incident Manager gives the adviser what data is involved, how many people, whether personal data was only at risk or confirmed accessed or copied, how sensitive it is (admission documents and finance files), and the time Northbridge became aware.
2. **Confirm roles and law.** Northbridge is the controller (A2). Nigerian law applies because Northbridge is a registered entity in Nigeria(A1), so the **Nigeria Data Protection Act 2023** is the main law. The adviser also checks whether learners live in other countries with their own rules, and checks contracts, partner agreements and the insurance policy for notice duties.
3. **Assess risk.** The adviser judges whether the breach is likely to risk people's rights and freedoms, and whether the risk is high.
4. **Confirm recipients and deadlines.** Under section 40 of the Nigeria Data Protection Act 2023, a controller must tell the Nigeria Data Protection Commission within 72 hours of becoming aware of a reportable breach (s.40(2)). Where there is a likely high risk to individuals, the controller must tell those people immediately (s.40(3)) (Federal Republic of Nigeria, 2023). As the Incident Response Lead, this is **my working assumption for Nigeria**, and our legal counsel must confirm it, including exactly when the 72 hours start. As a safe working rule, I would treat the clock as starting on Day 0 at about 09:00, so the working deadline is Day 3 (Thursday) 09:00 WAT.
5. **Approve and record.** The Executive Sponsor/CTO signs off the content and timing. The adviser records the reasons even if the decision is *not* to notify. Northbridge keeps a breach register.

Task 4cii. Operational Notices versus Formal Breach Notification

	Operational notice	**Formal breach notification**
Purpose	Tell people about service status, examination changes and safety steps.	Meet a legal duty by describing the breach to a regulator or affected individuals.
Owner	Communications Lead	Legal and Privacy Adviser
Approver	Executive Sponsor (and Business Owner for the examination)	Executive Sponsor on legal advice
Content	No statement that data was stolen unless confirmed.	Required legal content, based on confirmed facts and clearly stating what is not yet known.
Timing	As soon as it is useful.	Within the legal time limit.

Operational notices never contradict a later formal notice. Both use the same agreed facts.

Task 4ciii. Escalation Rules

Trigger	Escalate to	Time limit
Critical declared	Principal (Executive Sponsor), Business Owner	15 minutes
Evidence that personal data was copied or accessed	Legal and Privacy Adviser, Executive Sponsor, insurer	1 hour
Network backup tampered with or unreadable	Executive Sponsor, external IR firm, backup vendor	30 minutes
Attacker contacts Northbridge or threatens publication	Executive Sponsor and Legal Adviser (no reply without approval)	Immediately
Containment not achieved after 4 hours	External IR firm and the Principal	At 4 hours
Media or regulator enquiry	Communications Lead to Executive Sponsor and Legal Adviser	15 minutes
Possible criminal activity or extortion	Law enforcement, on legal advice	Same day

All Required outputs for Task 4 Completed: communication matrix (4a), executive briefing (4bi), learner notice (4bii), escalation rules (4ciii).

Part 3: Exercise and Critical Reflection

Task 5: Tabletop Exercise and Improvement Plan (15 marks)

Design a 60 minute tabletop exercise that tests your plan. State objectives, participant roles, an agenda, and at least three measurable success criteria. Walk through the exercise individually, taking the role of each participant. Clearly label the results as a simulation.

Exercise time	Required inject
Minute 10	Management asks you to reopen the learning portal before the 11:00 examination, even if the most recent backup is unverified.
Minute 20	An attacker claims to hold all 1,800 learner records and threatens publication in 12 hours. A screenshot is provided, but its authenticity is unknown.
Minute 35	A test restoration of the latest network backup fails with an unreadable snapshot error.
Minute 45	A social media post claims the examination is cancelled. A journalist asks whether learner information has been exposed.

- Add one further inject of your own. Record at least five decisions in a log with inject, decision, decision owner, rationale, communication, and effect on the response or recovery plan.
- Evaluate the simulated results against your success criteria. Identify at least five improvements and give each a priority, owner, target completion time, and measurable evidence of completion. Set a post incident review deadline and explain who closes the actions.

Task 6: Case Study Analysis and Critical Reflection (10 marks)

Write 300 to 400 words analysing the illustrative healthcare ransomware case on slide 16 of the teaching deck. Identify three response strengths and two limitations or unresolved issues. Explain two changes you would transfer to the Northbridge plan and justify their relevance.

Discuss why restoring critical systems within 72 hours differs from full restoration over seven days. Explain what evidence would be needed before claiming that no patient data was stolen. Identify one decision in your own plan that you would revise after the tabletop exercise.

The case in brief

A mid-size healthcare organisation (2,500 employees) was attacked through a phishing email with a malicious attachment. A Ryuk variant encrypted critical systems. The slide gives this timeline: Day 1 initial compromise, with about 72 hours of stealthy movement across the network; Day 4 EDR alerts, IR team activation, isolation and quarantine; Days 5 to 7 forensics, malware removal, rebuild from clean backups and phased restoration; Day 14 lessons-learned session, plan update, training and sharing with ISAC partners. Outcomes: no ransom paid, critical

systems back within 72 hours, no patient data exfiltration confirmed, regulatory notifications on time, seven days of total downtime (ICDFA Teaching slide deck pg. 16).

ANSWERS

Task 5. Tabletop Exercise and Improvement Plan

5.1 Exercise design

Everything in this section is a SIMULATION. It did not happen. The results are a paper walk-through that I completed alone, taking each role in turn, so they may be more favourable than a real group exercise.

Objectives

1. Test whether the plan lets the team decide about the examination safely when management is pressing to reopen the portal.
2. Test escalation to legal and privacy advice when an attacker makes a data theft claim.
3. Test backup validation and the fallback to the Friday disconnected backup.
4. Test communication with learners and the media through trusted channels.

Participant roles: Facilitator (controls the injections and timing); Incident Manager; Security Analyst; Forensics Specialist; IT Operations Lead; Business Owner; Legal and Privacy Adviser; Communications Lead; Executive Sponsor; Scribe.

Measurable success criteria

ID	Criterion
SC1	The CSIRT is activated through an out-of-band channel within 15 minutes of T0.
SC2	A decision on the examination is made within 10 minutes of Inject 1, and the learner notice is approved within 10 minutes of that decision.
SC3	100% of containment, restoration and notification decisions are logged with owner, rationale and approver.
SC4	The Legal Adviser is engaged and the awareness time is recorded within 15 minutes of Inject 2.
SC5	A holding statement is approved within 10 minutes of Inject 4 and contains no unconfirmed claims.
SC6	No restoration is approved unless all recovery acceptance criteria (section 3.6) are met.

Agenda (60 minutes). Exercise minute 0 is set at simulated 09:30 WAT on Day 0, after initial containment.

Exercise minute	Simulated time	Activity
0 to 5	09:30	Rules, scenario recap, current status, roles confirmed.
5 to 10	09:35	Review containment status and priorities.
10	09:40	**Inject 1:** management asks to reopen the portal before 11:00 even if the latest backup is unverified.
10 to 20		Discuss options, decide on the examination, draft the learner notice.
20	09:50	**Inject 2:** attacker claims to hold all 1,800 learner records and threatens publication in 12 hours (screenshot of unknown authenticity).
20 to 28		Treat the claim, brief legal, record awareness time.
28	09:58	**Inject 5 (my own):** analyst finds a forwarding rule on the finance officer's mailbox and a fake email in the Principal's name asking payroll to change bank details.
28 to 35		Respond to possible fraud and email compromise.
35	10:05	**Inject 3:** a test restore of the latest network backup fails with an unreadable snapshot error.
35 to 45		Decide the recovery path and the examination date.
45	10:15	**Inject 4:** a social media post says the examination is cancelled, and a journalist asks whether learner information has been exposed.
45 to 55		Prepare and approve the holding statement and learner correction.
55 to 60	10:25	Hot wash: score against criteria and record improvements.

5.2 Simulated walk-through, role by role (SIMULATION)

Inject	Simulated responses by role	Simulated outcome
1 (min 10) Reopen the portal	**Business Owner:** wants the 100 learners to sit at 11:00. **Executive Sponsor:** will accept reopening if the risk is low. **Incident Manager:** will not reopen from an unverified backup (E05 backup is the least trusted); offers a clean-room restore with a 10:15 go or no-go. **Security Analyst:** cannot vouch for the 02:00 backup. **IT Operations Lead:** a validated clean restore cannot be ready	The 11:00 examination is put on hold. The Business Owner accepts.

Inject	Simulated responses by role	Simulated outcome
	before about 11:30 at best. **Legal Adviser:** restoring tainted data could damage assessment records. **Communications Lead:** starts drafting the notice.	
2 (min 20) Attacker claim	**Security Analyst:** the screenshot cannot be authenticated; compares file names with FS01 paths and the E04 destination. **Forensics Specialist:** upload content (Q4) becomes top priority. **Legal Adviser:** treat as a possible breach, record awareness time (min 24), prepare a draft regulator notification. **Executive Sponsor:** no reply and no payment without approval; informs insurer. **Incident Manager:** preserves the screenshot as evidence; plans for early notification before the 12-hour limit. **Communications Lead:** prepares a phishing warning for learners. **Business Owner:** asks how continuity is affected.	The claim is treated as credible but unproven. Evidence work on Q4 is accelerated.
5 (min 28) Own inject: forwarding rule and fake payroll email	**Security Analyst:** removes the rule, checks the mailbox for other rules and sends mail. **IT Operations Lead:** resets the account, blocks the external address. **Business Owner (finance):** freezes all bank detail changes and requires call-back confirmation. **Communications Lead:** sends a phone and SMS warning to staff. **Legal Adviser:** possible fraud, advises reporting to police. **Incident Manager:** logs it as evidence and confirms email remains untrusted.	Payroll changes are frozen and staff are warned by phone and SMS.
3 (min 35) Backup fails	**IT Operations Lead:** the snapshot is unreadable, checks other restore points. **Security Analyst:** possible tampering, reviews BAK01 logs (EV-05). **Forensics Specialist:** images BAK01. **Incident Manager:** declares all network backups untrusted. **Business Owner:** accepts the examination moving to the earliest safe slot and accepts about 64 hours of lost work. **Executive Sponsor:** approves extra IR and backup vendor support. **Legal Adviser:** notes the availability loss for the record.	Recovery will use the Friday disconnected backup in a clean room. Recovery time estimate is extended.

Inject	Simulated responses by role	Simulated outcome
4 (min 45) Rumour and journalist	**Communications Lead:** drafts a holding statement and a correction to learners. **Legal Adviser:** wording must not deny exposure or claim it; say the matter is under investigation. **Executive Sponsor:** approves. **Incident Manager:** supplies only confirmed facts. **Business Owner:** confirms the examination is on hold, new date to be given by 13:00. **Security Analyst:** checks whether the post contains leaked data.	Holding statement and learner correction approved at minute 52 (7 minutes).

The learner notice, planned for 10:00 (minute 30), slipped to minute 38 in the simulation because the group waited for the Inject 3 result before sending it.

5.3 Decision log (SIMULATION)

	Inject	Decision	Decision owner	Rationale	Communication	Effect on response or recovery plan
D1	1	Do not reopen the production portal from the unverified backup. Prepare a clean-room restore.	Business Owner	The 02:00 backup is after the suspicious activity (E02, E03). Reinfection and corrupted assessment records are worse than a delay.	Executive Sponsor and learners told the examination is on hold.	Examination postponed. Clean-room restore becomes the recovery path.
D2	2	Treat the attacker claim as credible but unverified. No reply, no payment. Start breach assessment.	Executive Sponsor	The screenshot cannot be authenticated, but E04 makes theft plausible. Contact could weaken legal and insurance positions.	Legal Adviser, insurer and CSIRT briefed by phone.	Q4 upload analysis made top priority. Draft regulator notification prepared.
D3	5	Freeze bank detail changes and require call-backs. Treat	Business Owner (finance)	A fake request in the Principal's name suggests mailbox compromise.	Staff warned by phone and SMS.	New control added to the plan. Possible police report.

	Inject	Decision	Decision owner	Rationale	Communication	Effect on response or recovery plan
		email as compromised.				
D4	3	Declare network backups untrusted and use the Friday disconnected backup only.	Business Owner on the Incident Manager's recommendation	A failed restore plus E03 suggests tampering or damage.	Executive Sponsor and backup vendor informed.	Data loss accepted up to about 64 hours. The examination moves to the earliest safe slot.
D5	4	Issue a holding statement and a learner correction. Do not deny or confirm exposure.	Executive Sponsor	Facts are not confirmed. A denial could later be proved false.	Statement through website, social page and SMS.	Learners get one consistent message.
D6	2	Start the reporting clock log from Day 0 about 09:00 and prepare the regulator notification.	Executive Sponsor on the Legal Adviser's advice	The working legal limit is 72 hours (section 4.4). Early preparation avoids last-minute failure.	Legal Adviser leads.	Working deadline set at Day 3, 09:00 WAT.

5.4 Evaluation against success criteria (SIMULATION)

Criterion	Simulated result	Rating
SC1	CSIRT reached in 12 minutes, although two members answered only on a second call.	Met
SC2	Examination decision made in 8 minutes. Learner notice approval took 20 minutes after that decision, not 10.	Partly met
SC3	All six decisions logged with owner, rationale and approver.	Met
SC4	Legal Adviser engaged and awareness time recorded at minute 24, 4 minutes after the inject.	Met
SC5	Holding statement approved in 7 minutes with no unconfirmed claims.	Met
SC6	No restoration approved while backup validation was incomplete.	Met

Four criteria were met and one was partly met. ***Weak points were notice speed and slow phone contact.*** *SC6 was met only because the simulated restoration was never attempted before validation. A real exercise with several players may expose more problems.*

5.5 Improvement plan

	Improvement	Priority	Owner	Target completion	Measurable evidence of completion
1	Pre-approved learner and staff notice templates and an examination continuity procedure (postpone, clean-room, offline paper).	High	Communications Lead and Business Owner	14 days	Templates approved in writing. In the next exercise a notice is approved within 10 minutes.
2	Offline or immutable backups with quarterly restore tests.	Critical	IT Operations Lead	30 days	Restore test report for FS01 and LMS01 meeting the agreed RTO and RPO.
3	Printed and phone-held contact list, secondary messaging group, call-tree test.	High	Incident Manager	7 days	Test shows at least 90% of CSIRT reached within 30 minutes.
4	EDR on all servers and logging for BAK01.	Critical	Security Analyst	14 days	Coverage report shows 100% of servers reporting.
5	Finance fraud controls: call-back rule and bank-change freeze procedure.	High	Business Owner (finance)	14 days	Written procedure. One test call was completed successfully.
6	Legal retainer and breach-assessment checklist with a reporting clock log.	Medium	Executive Sponsor	30 days	Signed retainer. Checklist used in the next exercise.
7	Out-of-hours analyst cover through a managed detection service.	High	Executive Sponsor	60 days	Signed contract and a successful out-of-hours alert test.

Review deadline and closure. The hot wash is completed at the end of the exercise. The written exercise report and action owners are confirmed within 5 working days. Actions are reviewed every week and the full

action plan is checked after 30 days. For a real incident, the post-incident review takes place within 14 days of closure (ICDFA, slide 12). The **Incident Manager** tracks the actions and checks the evidence. The **Executive Sponsor** closes each action only after the evidence in the table above is seen, consistent with the RACI in section 2.

Task 6. Case Study Analysis and Critical Reflection

The slide 16 case describes a 2,500-employee healthcare organisation hit by a Ryuk ransomware variant after a phishing email. It is illustrative, so I would treat its lessons as examples, not proven facts.

Strengths. First, offline backups were verified intact on Day 4, which allowed recovery without paying a ransom. Second, EDR alerts triggered immediate IR team activation and the network segments were isolated, which limited spread. Third, a lessons-learned session on Day 14 updated the plan and shared intelligence with ISAC partners, matching the two-week review on teaching slide 12.

Limitations. First, malware moved sideways for 72 hours before encryption, so detection was slow, and the slide does not explain why earlier signals were missed. Second, "no patient data exfiltration confirmed" is given without evidence, and "not confirmed" is weaker than "ruled out".

Transfer to Northbridge. (1) Offline, tested backups. Northbridge's network backups are not immutable and have not been restore-tested in 90 days (E05), so I would add offline or immutable copies and quarterly restore tests. My recovery now depends on one Friday disconnected copy. (2) Network segmentation and least privilege. The portal depends on FS01 and svc_backup is an administrator on FS01 and BAK01 (E03), so segmentation would limit sideways movement.

72 hours versus seven days. Restoring critical systems within 72 hours means the services the organisation cannot work without are running again, often in a limited form. Full restoration over seven days adds every remaining system, data validation, hardening and a phased return. Reporting "recovered" at 72 hours can hide remaining risk, so I would report both milestones separately.

Evidence before claiming no patient data was stolen. I would need proxy, firewall, DNS and flow logs covering the whole 72-hour period of attacker presence, EDR records of file access or archive creation, cloud audit logs, a forensic review of affected hosts, checks of attacker leak sites and messages, and a written forensic conclusion that states its limits.

Decision I would revise. The tabletop showed that a 10:00 learner notice is too late: in the simulation it slipped to minute 38, and by minute 45 a social media post wrongly claimed cancellation. I would issue a provisional "examination on hold" notice by 09:30 and keep 10:15 as the final go or no-go point.

References

Anthropic (2026) *Claude Sonnet 5.5* [Large language model]. Available at: https://claude.ai (Accessed: October 17, 2026).

CISA (2023.) *#StopRansomware Guide*. Cybersecurity and Infrastructure Security Agency. Available at: https://www.cisa.gov/resources-tools/resources/stopransomware-guide

Federal Republic of Nigeria (2023) *Nigeria Data Protection Act 2023*, section 40. Official text available from the Nigeria Data Protection Commission (ndpc.gov.ng).

Google Gemini (2026) Gemini [Large language model]. Available at: https://gemini.google.com (Accessed: October 17, 2026).

ICDFA (2026.) *Incident Response Planning*. GRC105, Week 20. Teaching deck, slides 1 to 18.

NIST (2025) *SP 800-61 Revision 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management*. Available at: https://csrc.nist.gov/pubs/sp/800/61/r3/final

NIST (2025) *Incident Response project*. Available at: https://csrc.nist.gov/projects/incident-response

AI assistance acknowledgement: I used Gemini (Google Gemini, 2026) and Claude Sonnet 5.5 (Anthropic, 2026) on October 17, 2026 as writing and structural aids while working through the assignment requirements and Week 20 training slide course concepts. I reviewed, checked, and edited the generated content, and I am responsible for the final submission.

Reference Sources linked to the decisions they support

Source	Decision or section it supports
ICDFA (2026.), slides 6 to 13	Four-stage structure of the whole response; severity tiers and documentation (Tasks 1 and 2); containment, eradication and recovery steps (Task 3); lessons learned within two weeks (Tasks 2, 5).
ICDFA (2026.), slide 15	CSIRT roles and RACI pattern (Task 2).
ICDFA (2026.), slide 16	Case study analysis (Task 6).
ICDFA (2026.), slide 18	Link between incident response and business continuity (Task 2).
NIST (2025)	Alignment of the plan with the CSF 2.0 functions (Govern, Identify, Protect; Detect, Respond, Recover).
CISA (2023)	Isolation, evidence capture, MFA, backups and external support in the playbook (Task 3).

Source	Decision or section it supports
Federal Republic of Nigeria (2023)	Working 72-hour regulator notice and prompt notice to people at high risk (Task 4, Task 5 decision D6).